

ACTIVIDAD 09 DE 46 - LOGS SEGUROS Y ANALISIS DE EVENTOS CON IA

Segunda hora de clase (50 minutos) | Trabajo practico asistido con IA

Herramienta principal: opencode (CLI). Alternativas: ChatGPT, Claude, Copilot, Gemini.

Base normativa / marco de referencia: Monitorizacion y gestion de incidentes (OR.3, GR); proteccion de datos (Ley 18.331)

1. Contexto

Para detectar incidentes hay que registrar eventos. Hoy configuraras un logging seguro en tu API (sin datos personales, con formato JSON y request IDs) y usaras la IA para analizar los logs y detectar patrones sospechosos, como intentos de fuerza bruta o inyeccion.

2. Marco teorico

¿Que es el logging?

Es el registro sistematico de eventos de una aplicacion: quien, que, cuando, desde donde y con que resultado.

¿Que registra un log?

- Accesos y autenticaciones (exitosas y fallidas).
- Errores y excepciones.
- Operaciones criticas (transferencias, cambios de datos).

Que NO debe estar en un log

- Contraseñas ni tokens.
- Datos personales innecesarios.
- Informacion interna excesiva (si un log se filtra, la informacion se filtra).

Niveles de log

DEBUG (detalle), INFO (evento normal), WARNING (anomalía), ERROR (falla), CRITICAL (grave).

¿Para que sirve al RSI?

- Detectar incidentes y anomalías.
- Reconstruir que paso durante un incidente (evidencia).
- Alimentar el SIEM (actividad 31).

3. Objetivos de aprendizaje

- Configurar logging seguro en formato JSON (sin datos sensibles).
- Generar trafico para producir registros.
- Usar la IA para analizar logs y detectar anomalias.
- Documentar los patrones detectados y su relacion con incidentes.

4. Herramientas del dia (instalacion paso a paso)

Python logging (biblioteca estandar)

Configuras logging estructurado en JSON para tu API. No requiere instalacion.

1. Usa el modulo `logging` de Python ya incluido.
2. Opcional: `pip install python-json-logger` para formato JSON sencillo.

Terminal / curl + opencode

Generas trafico con curl y analizas los logs con opencode.

3. Ya instalado desde actividades previas.

5. Desarrollo paso a paso

Paso 1: Agregar logging a la API

Modifica app.py para registrar cada request con timestamp, metodo, ruta, status y request_id (seccion 5).

Paso 2: Evitar datos sensibles

Verifica que los logs no incluyan tokens, datos personales ni payloads completos.

Paso 3: Generar trafico

Ejecuta varias peticiones con curl, incluyendo intentos fallidos de autenticacion.

Paso 4: Guardar logs

Redirige la salida de logs a un archivo `evidencias/api.log`.

Paso 5: Analizar con IA

Pide a opencode que analice el archivo de logs y detecte patrones sospechosos.

Paso 6: Definir detecciones

Documenta 2 reglas simples de detecccion (por ejemplo, 5 fallos de login en 1 minuto).

Paso 7: Capturar evidencias

Guarda capturas de logs y del analisis de IA.

Paso 8: Documentar y reflexionar

Escribe el informe y tu reflexion.

6. Prompts sugeridos para la IA (opencode)

Copia y adapta estos mensajes en opencode (comando interactivo o `opencode` en terminal).

Configura logging en JSON para esta API Flask con request_id, sin registrar tokens ni datos personales: [pega tu codigo].

Analiza este archivo de logs e identifica patrones sospechosos (fuerza bruta, inyeccion, escaneos): [pega los logs].

Propón 5 reglas de deteccion de incidentes basadas en logs para una API financiera, con umbrales y accion.

7. Documentacion del RSI (bitacora)

Registra en `bitacora.md` de la carpeta de la actividad:

- Configuracion de logging aplicada.
- Logs generados y guardados.
- Patrones sospechosos detectados (con IA).
- Reglas de deteccion definidas.

8. Evidencias a capturar y guardar

Guarda cada evidencia en la carpeta `evidencias/` con el nombre EVI-YYYY-MM-DD-NN-descripcion.ext y registrala en la bitacora.

- EVI-...-01-api.log (archivo de logs).
- EVI-...-02-logging-json.png (codigo de logging).
- EVI-...-03-analisis-IA.png (patrones detectados).
- EVI-...-04-reglas-deteccion.md (reglas definidas).

9. Informe segun el marco de referencia

Elabora el informe de la actividad (archivo `informe.md`) que incluya:

- Como se registran los eventos (formato, campos).
- Patrones detectados en el analisis.
- Reglas de deteccion propuestas.
- Relacion con la gestion de incidentes (OR.3).

10. Entregable de la clase

API con logging seguro + archivo de logs + analisis con IA + reglas de deteccion.

Anexo A - Informe completo para presentar al BCU

Plantilla del informe ejecutivo que el RSI entregaria al Banco Central del Uruguay (BCU) por la actividad 09 - Logs seguros y analisis de eventos con IA. Completa los campos [entre corchetes] con los resultados reales de la actividad y adjunta las evidencias EVI-...

Encabezado del informe

Institucion: Banco Ficticio del Uruguay

Responsable de Seguridad de la Informacion (RSI): [Nombre y cargo]

Destinatario: Banco Central del Uruguay - Superintendencia de Instituciones Financieras

Asunto: Actividad 09 - Logs seguros y analisis de eventos con IA

Fecha: [dd/mm/aaaa] | Version: 1.0 | Clasificacion: Confidencial

1. Resumen ejecutivo

[2 a 5 parrafos breves: que se realizo, en que marco normativo, que se encontro, que se corrigio y el estado actual. Debe poder leerse en 1 minuto por un directivo.]

2. Marco normativo y regulatorio aplicable

- Norma de Seguridad de la Informacion y Ciberseguridad del BCU (SF.SEG.08).
- Recopilacion de Normas de Regulacion y Control del Sistema Financiero (RNRCSF).
- Circular sobre gestion de incidentes y notificacion de eventos de ciberseguridad.
- Normativa interna del Banco Ficticio del Uruguay: [politica de seguridad, plan de trabajo RSI].

3. Alcance y metodologia

- Alcance: [activos, procesos, sistemas o areas cubiertos por la actividad].
- Metodo: [pruebas tecnicas, revision documental, simulacion, escaneo, etc.].
- Herramientas utilizadas: Python logging (biblioteca estandar), Terminal / curl + openssl.
- Periodo de ejecucion: [fecha de inicio] a [fecha de fin].

4. Descripcion de la actividad

Para detectar incidentes hay que registrar eventos. Hoy configuraras un logging seguro en tu API (sin datos personales, con formato JSON y request IDs) y usaras la IA para analizar los logs y detectar patrones sospechosos, como intentos de fuerza bruta o inyeccion.

5. Resultados obtenidos

- Objetivo: Configurar logging seguro en formato JSON (sin datos sensibles). -> [Logrado / Parcial / No logrado]
- Objetivo: Generar trafico para producir registros. -> [Logrado / Parcial / No logrado]
- Objetivo: Usar la IA para analizar logs y detectar anomalias. -> [Logrado / Parcial / No logrado]
- Objetivo: Documentar los patrones detectados y su relacion con incidentes. -> [Logrado / Parcial / No logrado]

6. Riesgos identificados y evaluacion

Tabla de riesgos detectados con impacto en la institucion financiera:

ID Riesgo	Descripcion	Probabilidad	Impacto	Nivel	Tratamiento
R-01	[riesgo encontrado]	[A/M/B]	[A/M/B]	[C/E/M]	[Mitigado / Aceptado / En plan]
R-02	[riesgo encontrado]	[A/M/B]	[A/M/B]	[C/E/M]	[Mitigado / Aceptado / En plan]

7. Controles implementados

Descripcion de los controles aplicados y su estado:

- Control: Configura logging seguro en JSON -> [Implementado / Parcial / Pendiente]
- Control: Evita registrar datos sensibles -> [Implementado / Parcial / Pendiente]
- Control: Analiza logs con IA y detecta patrones -> [Implementado / Parcial / Pendiente]
- Control: Define reglas de deteccion -> [Implementado / Parcial / Pendiente]
- Control: Guarda y documenta las evidencias -> [Implementado / Parcial / Pendiente]

8. Incidentes de seguridad relacionados

[Ninguno en esta actividad. O bien: fecha, tipo, clasificacion, datos afectados, impacto y medidas adoptadas. Si corresponde, nota que ya se notifico al BCU en los plazos reglamentarios.]

9. Indicadores y metricas de la actividad

- Tiempo de ejecucion: [X] horas.
- Hallazgos: [X] altos, [X] medios, [X] bajos.
- Hallazgos corregidos: [X] / [X].
- Cobertura: [X]% de los activos del alcance.

10. Plan de accion y proximos pasos

Accion	Responsable	Plazo	Estado
[accion pendiente]	[cargo]	[dd/mm/aaaa]	Pendiente

11. Conclusion

[Conclusion ejecutiva: postura de seguridad de la institucion tras la actividad y compromiso de seguimiento.]

12. Firma y aprobacion

Firma del RSI: _____ Fecha: [dd/mm/aaaa]

Visto bueno del area de negocio / Direccion: _____

Anexos: evidencias EVI-... registradas en la bitacora.

Anexo B - Como presentar la actividad a AGESIC

Guia de estructura y contenido para comunicar la actividad 09 - Logs seguros y analisis de eventos con IA a la Agencia para el Desarrollo del Gobierno de Gestion Electronica y la Sociedad de la Informacion (AGESIC), alineada al marco de ciberseguridad de referencia para Uruguay.

Encuadre institucional

- Organismo: Banco Ficticio del Uruguay, dependencia publica.
- RSI: [Nombre y cargo] | Correo: [correo institucional].
- Fecha de presentacion: [dd/mm/aaaa] | Periodo cubierto: [periodo].

1. Presentacion del responsable

Quien es el RSI, su rol, a que direccion reporta y como se vincula con la gestion de la seguridad de la informacion en el Banco Ficticio del Uruguay.

2. Objetivo de la actividad

Para detectar incidentes hay que registrar eventos. Hoy configuraras un logging seguro en tu API (sin datos personales, con formato JSON y request IDs) y usaras la IA para analizar los logs y detectar patrones sospechosos, como intentos de fuerza bruta o inyeccion.

- Objetivo: Configurar logging seguro en formato JSON (sin datos sensibles).
- Objetivo: Generar trafico para producir registros.
- Objetivo: Usar la IA para analizar logs y detectar anomalias.
- Objetivo: Documentar los patrones detectados y su relacion con incidentes.

3. Marco de referencia utilizado

- Marco normativo de ciberseguridad aplicable (AGESIC / normativa nacional).
- Ley 18.331 de Proteccion de Datos Personales y su Decreto Reglamentario.
- Guia o documento de base: Monitorizacion y gestion de incidentes (OR.3, GR); proteccion de datos (Ley 18.331)
- Estandares de buenas practicas: [ISO/IEC 27001, NIST CSF, OWASP, etc.].

4. Metodología y herramientas

Como se desarrollo la actividad y con que herramientas (Python logging (biblioteca estandar), Terminal / curl + opencode).

5. Resultados y evidencias

Descripcion de lo obtenido, con referencia a las evidencias guardadas:

- Evidencia: EVI-...-01-api.log (archivo de logs).
- Evidencia: EVI-...-02-logging-json.png (codigo de logging).
- Evidencia: EVI-...-03-analisis-IA.png (patrones detectados).
- Evidencia: EVI-...-04-reglas-deteccion.md (reglas definidas).

6. Hallazgos, riesgos y recomendaciones

Presentacion de hallazgos ordenados por criticidad y las recomendaciones asociadas:

ID	Hallazgo	Criticidad	Recomendacion	Estado
H-01	[hallazgo]	[C/A/M/B]	[recomendacion]	[Abierto / Cerrado]

7. Gestion de incidentes (si aplica)

- Tipificacion del evento y datos involucrados.
- Notificacion a la Unidad Reguladora y de Control de Datos Personales si se vieron afectados datos personales.
- Lecciones aprendidas y mejoras al plan de respuesta.

8. Plan de mejora y continuidad

Mejora planificada	Responsable	Plazo	Prioridad
[mejora]	[cargo]	[dd/mm/aaaa]	[A/M/B]

9. Compromisos y firmas

El Banco Ficticio del Uruguay se compromete a [seguimiento, capacitacion, revision periodica] y presenta este informe para conocimiento de AGESIC.

Firma del RSI: _____ Sello del organismo: _____

11. Rubrica de evaluacion

Criterio	Logrado (3)	En desarrollo (2)	No logrado (1)
Configura logging seguro en JSON			
Evita registrar datos sensibles			
Analiza logs con IA y detecta patrones			
Define reglas de deteccion			
Guarda y documenta las evidencias			

12. Checklist de cierre

- ☐ Los logs tienen request_id y JSON.
- ☐ Generé trafico y guardé api.log.
- ☐ Documenté al menos 2 reglas de deteccion.

13. Reflexion sobre el uso de IA

¿Que cuidados exige el registro de logs respecto de la Ley 18.331? ¿Cuando es mas util la IA para analizar logs que las reglas fijas?